

SQL Injection Attacks

CompTIA PenTest+ (PT0-003)

Domains:

- 3.0: Vulnerability Discovery and Analysis
- 4.0: Attacks and Exploits

Objectives:

- 3.1: Given a scenario, conduct vulnerability discovery using various techniques.
- 4.5: Given a scenario, perform web application attacks using the appropriate tools.
- 4.10: Given a scenario, use scripting to automate attacks.

Video Overview

This video provides a foundational understanding of SQL Injection Attacks, a common web application vulnerability. This content is relevant for students preparing for the CompTIA PenTest+ certification, as it directly addresses objectives related to vulnerability discovery, web application attacks, and the use of scripting for automation. Understanding SQL injection is also valuable for anyone pursuing a career in cybersecurity or IT, as it highlights how applications interact with databases and how potential security flaws can be identified and addressed.

Key Topics Covered

- **SQL Injection Fundamentals:** Understanding SQL injection as a web application vulnerability where malicious SQL code is injected into database queries through unvalidated user input.
- **Identifying Injection Points:** Recognizing forms and input fields that interact with databases and testing for vulnerabilities using a single quote (').
- **Authentication Bypass:** Using boolean true statements (e.g., ' or 1=1 --) and inline comment characters to bypass login mechanisms.
- **Error-Based SQL Injection:** Leveraging verbose error messages to gather information about database structure, including column and table names.

- **Union-Based SQL Injection:** Employing the `UNION SELECT` statement to combine query results, identify display columns, and extract data like database users and versions.
- **Blind-Based SQL Injection (Time-Based):** Confirming successful SQL injection in the absence of visual output by using time-delay functions (e.g., `SLEEP()`).
- **Stacked Queries:** Executing multiple SQL statements in a single injection using a semicolon (`;`), with a note on database support variations.
- **Automated SQL Injection with SQLMap:** Utilizing SQLMap as an automated tool for testing, enumerating databases, tables, and columns, and dumping sensitive data.

Student Notes Section